Firewall Audit Report — Laboratory Work 2

Dataset window: **2024-11-13 18:02:22** to **2024-11-14 17:52:24** | Total sessions: **781** (ALLOW: **656**, DENY: **125**)

1) Was the firewall migration performed securely?

Evidence suggests issues post-migration: ALLOW on high-risk outbound ports (4444/6667/1080/9050) and DNAT exposures of sensitive services (SSH/RDP/DB).

2) What type of issue was identified?

Firewall misconfiguration (overly permissive outbound) and unsafe DNAT port-forwarding to internal services.

3) Which internal assets are at risk?

Sensitive DNAT exposures (external → internal)

external_ip	external_port	internal_ip	internal_port	sessions	allowed	denied
203.0.113.1	3306	10.10.2.50	3306	18	18	0

Allowed outbound on high-risk ports

timestamp	src_ip	dst_ip	dst_port	protocol	bytes_sent	nat_src	nat_dst
2024-11-14 03:20:00	10.10.3.15	91.108.56.130	9050	TCP	1274	203.0.113.2	nan
2024-11-14 03:49:00	10.10.3.15	91.108.56.130	9050	TCP	1242	203.0.113.2	nan
2024-11-14 05:06:00	10.10.3.15	91.108.56.130	9050	TCP	1835	203.0.113.2	nan
2024-11-14 06:30:00	10.10.3.15	91.108.56.130	9050	TCP	838	203.0.113.2	nan
2024-11-14 06:36:00	10.10.3.15	91.108.56.130	9050	TCP	889	203.0.113.2	nan
2024-11-14 08:08:00	10.10.3.15	91.108.56.130	9050	TCP	1213	203.0.113.2	nan
2024-11-14 09:15:00	10.10.3.15	91.108.56.130	9050	TCP	953	203.0.113.2	nan
2024-11-14 09:24:00	10.10.3.15	91.108.56.130	9050	TCP	1847	203.0.113.2	nan

Potential data exfiltration indicator

High bytes_sent sessions (>= 153,852 bytes):

Top high-bytes sessions

timestamp	src_ip	dst_ip	dst_port	protocol	action	bytes_sent	nat_src	nat_dst
2024-11-14 04:47:00	10.10.3.15	91.108.56.130	443	TCP	ALLOW	239353	203.0.113.2	nan
2024-11-14 10:42:00	10.10.3.15	91.108.56.130	443	TCP	ALLOW	204811	203.0.113.2	nan
2024-11-14 05:50:00	10.10.3.15	91.108.56.130	443	TCP	ALLOW	193650	203.0.113.2	nan
2024-11-14 07:15:00	10.10.3.15	91.108.56.130	443	TCP	ALLOW	173587	203.0.113.2	nan

4) What should the company do next?

1) Remove/restrict unsafe DNAT; allowlist sources. 2) Default-deny outbound; block non-standard ports. 3) Ensure stateful rules (ESTABLISHED/RELATED). 4) Enable full logging on ALLOW+DENY and alert on new NAT mappings. 5) Enforce MFA/VPN for any remote admin access.

Appendix: Evidence tables

Top sources by DENY events

src_ip	deny_sessions
185.220.101.47	45
10.10.1.27	5
10.10.3.10	4
10.10.2.20	4
10.10.3.23	4
10.10.3.24	4
10.10.3.13	3
10.10.1.22	3
10.10.2.21	3
10.10.2.19	3

All DNAT mappings (top)

external_ip	external_port	internal_ip	internal_port	sessions	allowed	denied
203.0.113.1	443	10.10.1.100	443	20	20	0
203.0.113.1	3306	10.10.2.50	3306	18	18	0

SNAT/Routing leaks (RFC1918 destination)

No data.

Charts

chart1_allow_deny_per_hour.png

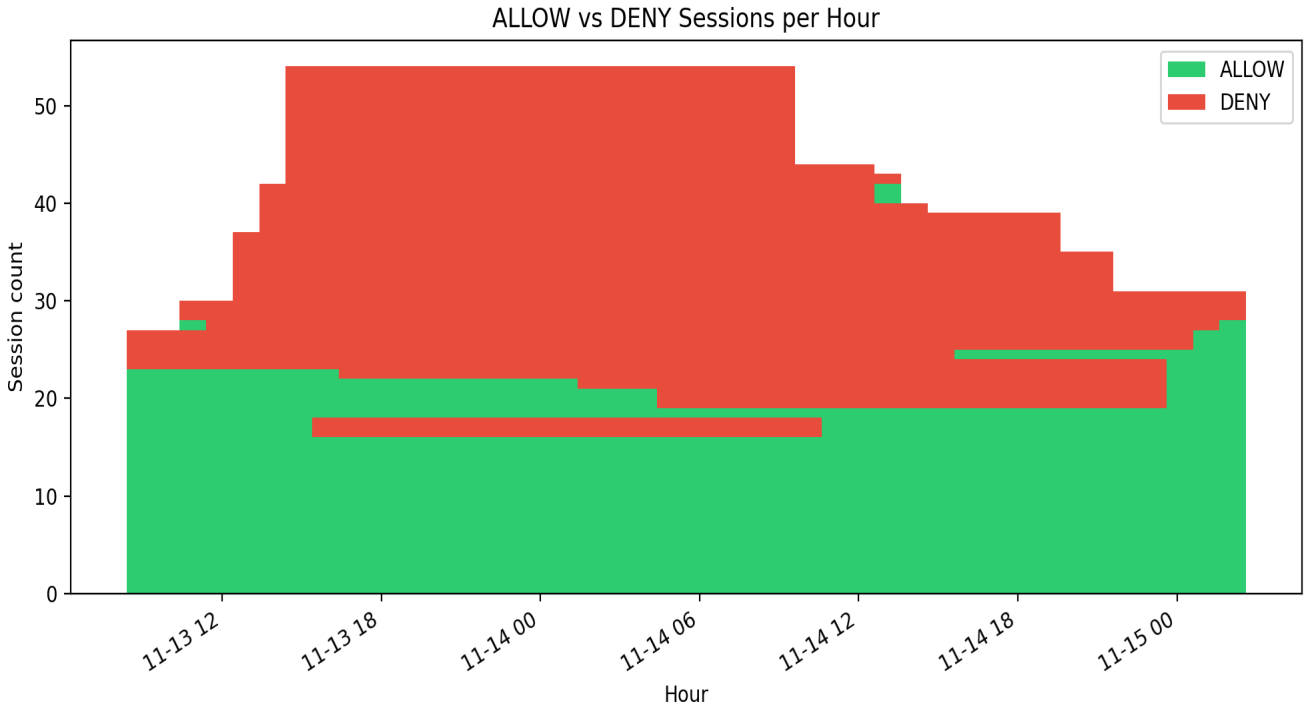

chart2_top_ports_split_by_action.png

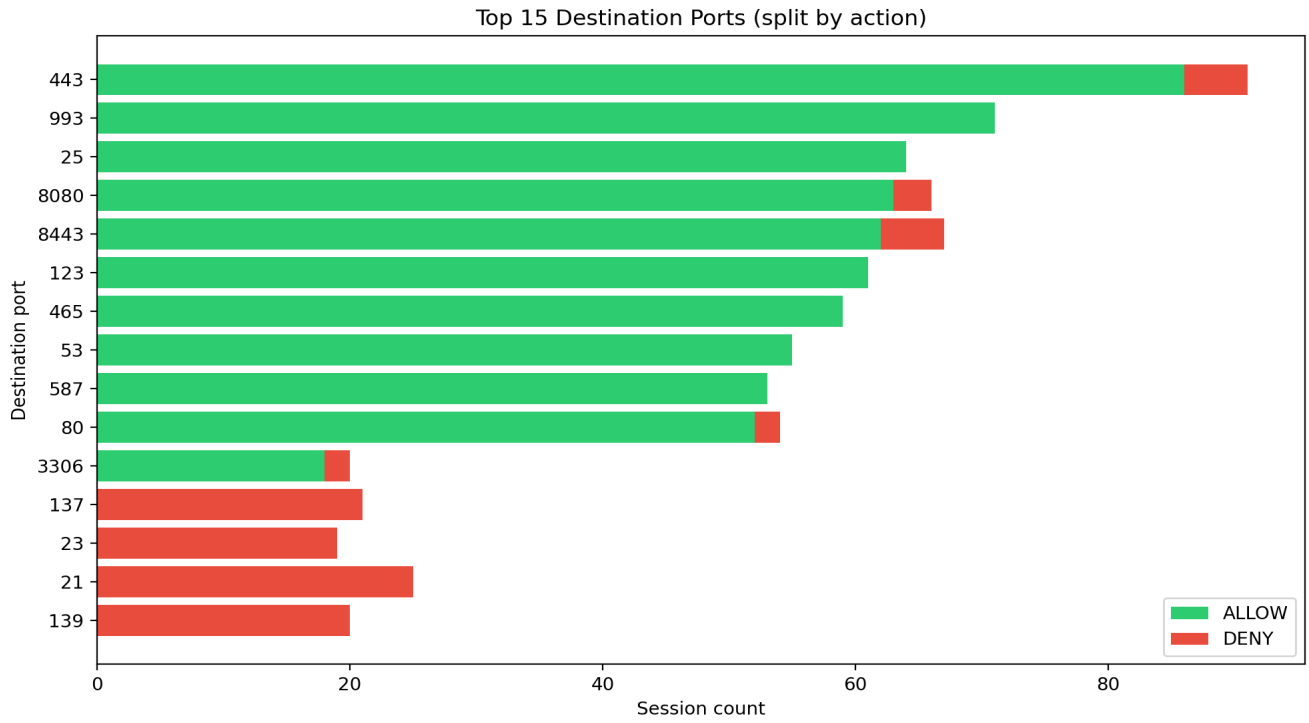
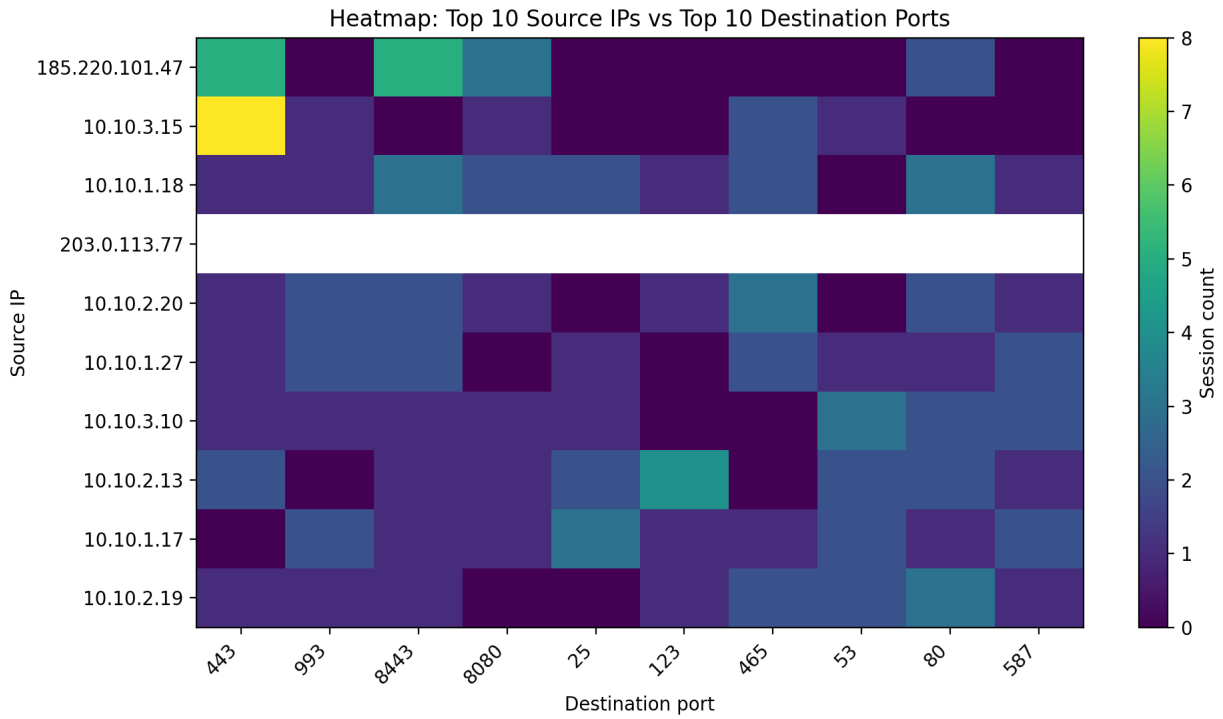
chart3_heatmap_top_src_vs_ports.png